Rapport d'intégration - Envoi des proformas et factures par e-mail

Oct 12, 2026 · @WOOM

1. Résumé exécutif

Recommandation : envoyer les proformas et factures depuis votre propre serveur (une route `api/send-document.js` sur Vercel), via l'API Microsoft Graph depuis les boîtes Microsoft 365 de chaque marque, avec le PDF en pièce jointe. Passer par l'API VosFactures n'est pas conseillé dans l'état actuel du projet.

Proforma Studio ne pousse aujourd'hui aucun document dans VosFactures : il n'en importe que les clients. Utiliser l'envoi VosFactures obligerait à recréer chaque document là-bas, avec une seconde numérotation en parallèle de `proforma_sequences` et `invoice_sequences`.

Pourquoi Microsoft 365 plutôt qu'un fournisseur tiers : vos messageries sont déjà gérées par Microsoft 365 Business Standard. Les e-mails partent donc des vraies boîtes de marque, apparaissent dans leurs éléments envoyés, utilisent des domaines déjà configurés et n'ajoutent ni fournisseur, ni facture d'envoi. En contrepartie, le suivi de livraison est plus limité (section 5), et un administrateur Microsoft 365 doit créer une inscription d'application et la restreindre aux boîtes de marque.

Impact sur la base : 2 nouvelles tables (`email_messages` , `brand_email_settings`), quelques colonnes ajoutées à `contacts` , `proformas` , `invoices` et `user_profiles` , un bucket Storage privé. Tout tient dans un script idempotent, `supabase/email-delivery.sql` . Aucune colonne existante n'est modifiée ou supprimée.

Prérequis bloquant : l'inscription est ouverte à tous. Sans validation des comptes, n'importe qui pourrait envoyer des e-mails au nom de l'entreprise. La colonne `approved_at` proposée en section 6 doit être en place avant d'activer l'envoi.

Effort estimé : environ 10 à 15 jours de développement, livrables en 4 phases (section 12). Ce chiffre est une estimation à confirmer avec votre développeur.

2. Contexte et périmètre

L'étude couvre l'envoi par e-mail des proformas et des factures `FAC-…` générées par Proforma Studio, au client et au responsable de la structure, avec suivi de chaque envoi.

Situation actuelle : l'application produit un aperçu A4, puis un PDF via le dialogue d'impression du navigateur. Aucun fichier PDF n'existe côté serveur, donc l'envoi se fait à la main (WhatsApp, messagerie personnelle) et rien n'est tracé. Le formulaire client public fonctionne par lien WhatsApp, sans envoi automatique.

Dans le périmètre

- Envoi déclenché par un utilisateur connecté, depuis Archives ou l'Éditeur.
- Destinataires en À et en copie, PDF joint, objet et message préremplis.
- Journal des envois, statut de livraison, renvoi.
- Relance des proformas validées mais non réglées (phase ultérieure).

Hors périmètre : signature électronique, paiement en ligne, envois en masse, envoi automatique par WhatsApp.

Point à trancher : « responsable de la structure » peut désigner le responsable côté client (la personne qui valide, `customer_requests.validation_contact`) ou le responsable interne de la marque mis en copie. Le modèle proposé gère les deux (décision n°1, section 13).

3. Analyse du schéma actuel

Le schéma couvre déjà l'essentiel (documents figés, propriété par `user_id`, historique) ; il manque la trace des envois, un e-mail dédié au responsable et un état d'approbation des comptes.

Table	Ce qui est réutilisé	Ce qui manque pour l'e-mail
`contacts`	`emails`, `email_rappels`, `contact`, `nom`	Pas d'adresse dédiée au responsable. Le format de `emails` (plusieurs adresses dans un seul texte) est à vérifier sur vos données.
`proformas`	`data` (client, lignes, e-mail client), `profile_snapshot`, `amount`, `status`, `deleted_at`, `validation_status`, `payment_received_at`, `invoice_id`	Aucune trace des envois.
`invoices`	`proforma_id`, `number`, `data`, `profile_snapshot`, `status`	Aucune trace des envois. Pas de date d'échéance ni de statut « payée ».

Table	Ce qui est réutilisé	Ce qui manque pour l'e-mail
`customer_requests`	`email`, `validation_contact`, `proforma_id`	Un seul e-mail pour deux rôles (demandeur et validation).
`activity_events`	`event_type`, `entity_type`, `entity_id`, `details`, `source_event_id`	Rien : réutilisable tel quel pour journaliser les envois.
`user_profiles`	`matricule_3cx`	Ni rôle, ni état d'approbation.
Marques (absent)	—	Pas de table des marques. L'identité vit dans le navigateur et est copiée dans `profile_snapshot` : aucun expéditeur ni copie interne partagés.

Conséquence de la confidentialité par compte : les archives sont privées (`proformas.user_id`). Seul l'auteur d'un document peut l'envoyer et voir ses envois. Le responsable interne reçoit une copie par e-mail (`internal_cc`), il n'obtient pas d'accès à l'application.

Conséquence du flux de validation : une facture n'est générée qu'après validation orale, commande confirmée et paiement reçu. Les relances ne concernent donc pas les factures mais les proformas validées dont `payment_received_at` est vide (section 11).

4. Besoins fonctionnels

Douze besoins couvrent l'envoi, la traçabilité et la relance ; les 8 premiers forment le MVP (phase 1).

#	Besoin	Phase
R1	Envoyer une proforma enregistrée au client (À), PDF joint	1
R2	Mettre le responsable en copie : responsable client et/ou responsable interne de la marque	1
R3	Objet et message préremplis par gabarit, modifiables avant envoi	1
R4	Bloquer l'envoi d'une proforma sans prix (`amount = 0`), supprimée ou encore en brouillon	1

#	Besoin	Phase
R5	Empêcher le double envoi (double clic, rechargement, réseau instable)	1
R6	Envoyer la facture `FAC-…` juste après « Générer la facture »	1
R7	Journaliser chaque envoi dans l'historique d'activité	1
R8	Limiter les envois par utilisateur et réserver la fonction aux comptes approuvés	1
R9	Afficher le statut : en cours, envoyé, livré, rebond, échec	2
R10	Renvoyer un document et consulter tous ses envois	2
R11	Expéditeur par marque (nom, adresse de réponse, signature)	2
R12	Relancer les proformas validées mais non réglées	3

Règle de destinataires proposée

- **À** : l'e-mail client saisi sur le document (`data.clientEmail`). À défaut, le premier e-mail valide de `contacts.emails` . On utilise la copie figée du document, pas la fiche vivante, pour rester cohérent avec ce que le client a reçu.
- **Copie** : `contacts.email_responsable` (nouveau champ) puis `brand_email_settings.internal_cc` pour la marque.
- **Relances** : `contacts.email_rappels` en priorité.
- Au plus 5 destinataires par envoi, adresses normalisées en minuscules, doublons retirés.

5. Options d'architecture

Option A1 (serveur propre + Microsoft Graph, depuis vos boîtes Microsoft 365) est la mieux adaptée : elle réutilise votre numérotation, vos snapshots, vos domaines déjà authentifiés et vos routes `api/` .

Critère	A1. Microsoft Graph depuis vos boîtes M365 (recommandé)	A2. Fournisseur d'e-mail tiers	B. API VosFactures	C. Envoi manuel
Principe	La route appelle Graph avec une identité d'application, au nom de la boîte de la marque	La route appelle le fournisseur ; chaque domaine est à ajouter et authentifier	Recréer le document dans VosFactures, puis déclencher son envoi	L'utilisateur envoie lui-même le fichier
Boîtes et domaines	Déjà en place, authentification gérée par Microsoft 365	À configurer un par un (DNS)	À configurer chez VosFactures	Messagerie de l'utilisateur
Éléments envoyés et réponses	Dans la boîte de la marque	Hors de votre messagerie	Selon VosFactures	Oui
Suivi de livraison	Limité : statut « envoyé », un rebond revient comme e-mail d'erreur dans la boîte	Complet, par webhook	Limité à ce qu'expose VosFactures	Aucun
Numérotation	Conservée	Conservée	Deuxième numéro attribué par VosFactures	Conservée
Coût et dépendance	Licences déjà payées ; une inscription d'application à créer et un secret à renouveler	Abonnement du fournisseur	Plan VosFactures, quotas et API (à confirmer dans leur documentation)	Aucun
Adéquation au schéma	Forte : ajout de tables, aucun changement existant	Forte	Faible : il faudrait stocker les identifiants VosFactures des documents	Sans objet

Ce que l'option A1 apporte

- Le message part de la boîte de la marque : éléments envoyés et réponses des clients au même endroit.
- Domaines et authentification (SPF, DKIM) déjà gérés par Microsoft 365, sans nouvelle vérification de domaine.
- Aucun mot de passe de messagerie stocké : l'accès passe par une identité d'application.

Ce qu'elle coûte

- Pas de webhook de statut : un rebond arrive sous forme d'e-mail d'erreur dans la boîte, à détecter en phase 2.
- D'après la documentation habituelle de Graph, l'envoi direct ne renvoie pas d'identifiant de message : on crée un brouillon, puis on l'envoie, pour garder l'identifiant. À confirmer à l'essai.
- Pas de clé d'idempotence côté Graph : la protection contre le double envoi repose sur notre propre ligne `email_messages`.
- Une pièce jointe directe est limitée à 3 Mo ; au-delà il faut une session de téléversement (jusqu'à 150 Mo au total). Un PDF de proforma tient très largement dans 3 Mo.
- Un administrateur Microsoft 365 doit créer l'inscription d'application, la restreindre aux boîtes de marque et noter la date d'expiration de son secret.

À écarter : l'envoi SMTP avec identifiant et mot de passe. Microsoft prévoit de désactiver l'authentification basique SMTP par défaut fin décembre 2026 pour les organisations existantes, et la date de suppression définitive sera annoncée au second semestre 2027.

VosFactures reste utile en complément : l'import des clients continue, et une synchronisation des factures émises vers VosFactures pourra être étudiée plus tard pour la comptabilité.

Génération du PDF : trois méthodes possibles.

Méthode	Fidélité à l'aperçu A4	Coût de mise en œuvre	Point d'attention
1. Navigateur sans interface côté serveur (Chromium)	Très bonne	Élevé : il faut extraire le rendu de `index.html` dans un module partagé	Taille de la fonction, temps de démarrage, limites de durée et de mémoire du plan Vercel à vérifier

Méthode	Fidélité à l'aperçu A4	Coût de mise en œuvre	Point d'attention
2. PDF produit dans le navigateur de l'utilisateur, déposé dans Supabase Storage	Bonne, car c'est le même rendu que l'aperçu	Faible	Les sauts de page (« sans couper les articles ») sont à tester ; le PDF est fourni par le client, d'où le contrôle de signature `%PDF` et d'empreinte
3. Lien sécurisé vers une page de consultation, sans pièce jointe	Bonne	Moyen : nouvelle page publique avec jeton	Le client doit cliquer ; peu pratique à transférer

Recommandation PDF : la méthode 2 en phase 1, parce que l'application est un fichier `index.html` unique et que cette méthode évite de réécrire le rendu côté serveur. Si la fidélité pose problème, passer à la méthode 1 en phase 3. Chaque envoi fige son PDF dans Storage (dossier `{user_id}/{type}/…`), ce qui conserve la preuve de ce qui a été envoyé.

Choix de la voie d'envoi (décision n°2) : Microsoft Graph si votre administrateur Microsoft 365 peut créer l'inscription d'application et la restreindre à quelques boîtes ; sinon un fournisseur tiers (A2). Dans ce second cas, comparer l'authentification du domaine d'envoi (SPF, DKIM, DMARC), les webhooks de statut, la taille maximale de pièce jointe, la prise en charge d'une clé d'idempotence, le nombre de domaines inclus dans le plan et le prix.

6. Évolutions du schéma Supabase

Un seul script, `supabase/email-delivery.sql`, à exécuter après `proformas-history.sql`, `contacts-write.sql` et `client-forms.sql`. Il n'utilise que `if not exists` et ne touche à aucune politique existante.

Ce qui est ajouté

- `user_profiles` : `role` (agent ou admin) et `approved_at`, pour valider les comptes.
- `contacts` : `nom_responsable` et `email_responsable`. L'import VosFactures ne les renseigne pas, donc il ne les écrase pas ; il faut simplement ne pas les ajouter à son `upsert`.

- `brand_email_settings` : expéditeur, date du premier envoi test réussi depuis la boîte de la marque, adresse de réponse, copie interne et signature, par marque. Tant que cette date est vide, la marque ne peut pas envoyer.
- `email_messages` : une ligne par envoi (destinataires, statut, identifiant du message, empreinte du PDF, clé d'idempotence).
- `proformas` et `invoices` : `last_emailed_at` et `email_send_count`, tenus à jour par un déclencheur, pour afficher un badge sans jointure.
- Un bucket Storage privé `documents`, en lecture et dépôt limités au dossier de l'utilisateur, sans modification ni suppression.

```
-- supabase/email-delivery.sql

-- 1. Rôle et approbation des comptes
alter table public.user_profiles
  add column if not exists role text not null default 'agent';

do $$ begin
  alter table public.user_profiles
    add constraint user_profiles_role_check check (role in ('agent',
'admin'));
exception when duplicate_object then null; end $$;

-- approved_at : la colonne est créée une seule fois ; les comptes existants
sont approuvés
-- à ce moment-là seulement, pour qu'une réexécution n'approuve pas les
nouveaux inscrits.
do $$ begin
  if not exists (
    select 1 from information_schema.columns
    where table_schema = 'public' and table_name = 'user_profiles' and
column_name = 'approved_at'
  ) then
    alter table public.user_profiles add column approved_at timestamptz;
    update public.user_profiles set approved_at = now();
  end if;
end $$;

create or replace function public.is_admin() returns boolean
language sql stable security definer set search_path = public as $$
  select exists (
    select 1 from public.user_profiles
    where id = auth.uid() and role = 'admin' and approved_at is not null
  );
$$;
```

```
-- 2. Responsable côté client (l'import VosFactures ne touche pas ces
colonnes)
alter table public.contacts
  add column if not exists nom_responsable text,
  add column if not exists email_responsable text;

-- 3. Réglages d'envoi par marque
create table if not exists public.brand_email_settings (
  brand_id text primary key,
  sender_name text not null,
  sender_email text not null,  -- boîte Microsoft 365 de la marque (boîte
partagée conseillée)
  sender_verified_at timestamptz,
  reply_to text,
  internal_cc text[] not null default '{}',
  signature_text text,
  is_active boolean not null default true,
  updated_by uuid references auth.users(id),
  updated_at timestamptz not null default timezone('utc'::text, now())
);
alter table public.brand_email_settings enable row level security;

drop policy if exists brand_email_settings_read on
public.brand_email_settings;
create policy brand_email_settings_read on public.brand_email_settings
  for select to authenticated using (true);

drop policy if exists brand_email_settings_admin on
public.brand_email_settings;
create policy brand_email_settings_admin on public.brand_email_settings
  for all to authenticated using (public.is_admin()) with check
(public.is_admin());
-- Insérer ensuite une ligne par brand_id réellement utilisé dans le code
(les 9 marques).

-- 4. Journal des envois
create table if not exists public.email_messages (
  id uuid primary key default gen_random_uuid(),
  user_id uuid not null references auth.users(id),
  brand_id text not null,
  document_type text not null check (document_type in ('proforma',
'invoice')),
  proforma_id uuid references public.proformas(id),
  invoice_id uuid references public.invoices(id),
  request_id uuid references public.customer_requests(id),
```

```
  contact_id uuid references public.contacts(id),
  template text not null default 'document',
  subject text not null,
  to_emails text[] not null check (cardinality(to_emails) between 1 and 5),
  cc_emails text[] not null default '{}',
  reply_to text,
  attachment_path text,
  attachment_sha256 text,
  provider text not null,
  provider_message_id text,  -- Graph : internetMessageId du message envoyé
  status text not null default 'queued'
    check (status in ('queued', 'sent', 'delivered', 'delayed', 'bounced',
'complained', 'failed')),
  error text,
  idempotency_key text not null,
  sent_at timestamptz,
  delivered_at timestamptz,
  created_at timestamptz not null default timezone('utc'::text, now()),
  updated_at timestamptz not null default timezone('utc'::text, now()),
  constraint email_messages_one_document check (num_nonnulls(proforma_id,
invoice_id) = 1)
);

create unique index if not exists email_messages_idem_uidx
  on public.email_messages (user_id, idempotency_key);
create index if not exists email_messages_proforma_idx on
public.email_messages (proforma_id);
create index if not exists email_messages_invoice_idx on
public.email_messages (invoice_id);
create index if not exists email_messages_provider_idx on
public.email_messages (provider_message_id);

alter table public.email_messages enable row level security;
drop policy if exists email_messages_select_own on public.email_messages;
create policy email_messages_select_own on public.email_messages
  for select to authenticated using (user_id = auth.uid());
-- Aucune politique d'écriture : seules les routes serveur (clé service)
écrivent.

create or replace function public.email_messages_touch() returns trigger
language plpgsql as $$
begin new.updated_at = timezone('utc'::text, now()); return new; end $$;

drop trigger if exists email_messages_touch_trg on public.email_messages;
create trigger email_messages_touch_trg before update on
public.email_messages
```

```
  for each row execute function public.email_messages_touch();

-- 5. Badge « envoyée » sur les documents
alter table public.proformas
  add column if not exists last_emailed_at timestamptz,
  add column if not exists email_send_count integer not null default 0;
alter table public.invoices
  add column if not exists last_emailed_at timestamptz,
  add column if not exists email_send_count integer not null default 0;

create or replace function public.email_messages_mark_document() returns
trigger
language plpgsql security definer set search_path = public as $$
begin
  if new.status in ('sent', 'delivered')
     and (tg_op = 'INSERT' or old.status not in ('sent', 'delivered')) then
    if new.proforma_id is not null then
      update public.proformas
         set last_emailed_at = coalesce(new.sent_at, now()),
             email_send_count = email_send_count + 1
       where id = new.proforma_id;
    elsif new.invoice_id is not null then
      update public.invoices
         set last_emailed_at = coalesce(new.sent_at, now()),
             email_send_count = email_send_count + 1
       where id = new.invoice_id;
    end if;
  end if;
  return new;
end $$;

drop trigger if exists email_messages_mark_document_trg on
public.email_messages;
create trigger email_messages_mark_document_trg
  after insert or update of status on public.email_messages
  for each row execute function public.email_messages_mark_document();

-- 6. Stockage privé des PDF envoyés (immuables : pas de update ni delete)
insert into storage.buckets (id, name, public, file_size_limit,
allowed_mime_types)
values ('documents', 'documents', false, 3145728, array['application/pdf'])
on conflict (id) do nothing;

drop policy if exists documents_own_read on storage.objects;
create policy documents_own_read on storage.objects
  for select to authenticated
```

```
  using (bucket_id = 'documents' and (storage.foldername(name))[1] =
auth.uid()::text);

drop policy if exists documents_own_insert on storage.objects;
create policy documents_own_insert on storage.objects
  for insert to authenticated
  with check (bucket_id = 'documents' and (storage.foldername(name))[1] =
auth.uid()::text);
```

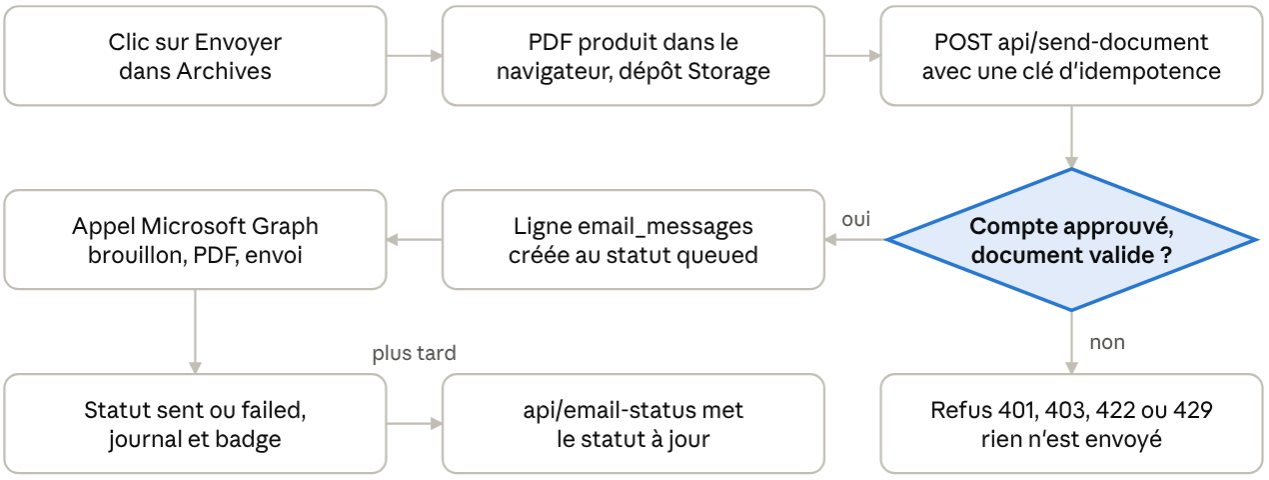
À contrôler avant exécution

- Le script `3cx-auth.sql` crée le profil à l'inscription : les nouveaux comptes auront bien `approved_at` vide, donc non approuvés par défaut.
- Si `proformas` ou `invoices` portent déjà un déclencheur qui refuse les mises à jour d'un document validé, celui du badge devra en tenir compte.
- La mise à jour de `brand_email_settings` suppose qu'au moins un compte soit passé en `role = 'admin'` à la main.

7. Route serveur et flux d'envoi

Une route authentifiée, `api/send-document.js`, contrôle tout puis envoie par Microsoft Graph ; une seconde, `api/email-status.js`, suit les rebonds et met à jour les statuts. Toutes deux suivent le modèle de `api/import-vosfactures-clients.js` et de `api/client-form.js`.

Rien ne part sans contrôle serveur ni ligne de journal



flux d'envoi · 1 contrôle, 1 refus

Le contrôle est le seul point de passage : en cas d'échec, aucune ligne n'est créée et aucun e-mail ne part.

Contrôles de la route, dans l'ordre

1. Session Supabase valide (JWT), sinon 401.
2. Compte approuvé (`approved_at` renseigné), sinon 403.
3. Document chargé avec le JWT de l'utilisateur : la RLS garantit qu'il en est l'auteur. `deleted_at` doit être vide, sinon 404.
4. Proforma : `amount > 0`, statut enregistré, pas en attente de prix. Facture : liée à une proforma existante. Boîte d'envoi de la marque active, avec un premier envoi test réussi. Sinon 422.
5. Destinataires : adresses valides, 5 au plus, minuscules, doublons retirés ; la copie interne est ajoutée depuis `brand_email_settings`. Sinon 422.
6. Quota par utilisateur (par exemple 30 envois par heure, compté dans `email_messages`), sinon 429. Le chiffre est à ajuster.
7. PDF : le chemin commence par l'identifiant de l'utilisateur, taille d'au plus 3 Mo (limite de la pièce jointe directe de Graph), signature `%PDF` vérifiée, empreinte SHA-256 enregistrée.
8. Ligne `queued` créée avec la clé d'idempotence unique. Un doublon renvoie l'envoi existant sans rien renvoyer. Une ligne `queued` ancienne, sans identifiant de message, n'est jamais renvoyée automatiquement : elle est signalée « à vérifier dans les éléments envoyés de la boîte ».
9. Envoi par Microsoft Graph (détail ci-dessous), puis statut `sent` ou `failed` et événement dans `activity_events`.

Contrat de la route

```
{
  "documentType": "proforma",
  "documentId": "<uuid de la proforma ou de la facture>",
  "to": ["client@exemple.ci"],
  "cc": ["responsable@exemple.ci"],
  "subject": "Proforma n° … — <marque>",
  "message": "Texte modifiable avant envoi",
  "pdfPath": "<user_id>/proforma/<numéro>-<révision>.pdf",
  "idempotencyKey": "<uuid généré à chaque clic>"
}
```

Réponse : `{ ok, emailMessageId, status }`. Un nouvel essai volontaire après un échec utilise une nouvelle clé ; un rechargement de la page réutilise la même.

Appel à Microsoft Graph (étape 9)

1. Jeton d'application obtenu avec les identifiants de l'inscription (flux « client credentials »), gardé en mémoire jusqu'à son expiration.

2. Brouillon créé dans la boîte de la marque (`POST /users/{sender_email}/messages`) avec destinataires, copie, adresse de réponse, corps et PDF en pièce jointe. La réponse donne l' `internetMessageId` , enregistré dans `provider_message_id` .
3. Envoi du brouillon (`POST /users/{sender_email}/messages/{id}/send`). Le message apparaît dans les éléments envoyés de la boîte.
4. Mise à jour de `email_messages` et événement d'historique. Un refus de Graph (jeton invalide, boîte hors périmètre, limite atteinte) donne `failed` , avec le motif dans `error` .

Les chemins et propriétés exacts sont à confirmer dans la documentation Microsoft Graph au moment du développement.

Suivi des rebonds (phase 2)

- En phase 1, le statut final est `sent` (accepté par Exchange Online) ou `failed` .
- En phase 2, option simple : une tâche planifiée lit les e-mails d'erreur de remise reçus dans la boîte de chaque marque et les rattache à la ligne `email_messages` par l'identifiant du message, puis passe le statut à `bounced` . Elle demande une autorisation de lecture, limitée aux boîtes de marque comme l'envoi.
- Option avancée : un abonnement Graph aux nouveaux messages de la boîte, avec notification vers une route de l'application, à renouveler régulièrement.
- Dans tous les cas, le traitement est idempotent, et un rebond ajoute un événement à l'historique et un badge d'alerte sur le document.

8. Gabarits d'e-mail et pièce jointe

Trois gabarits suffisent (proforma, facture, relance), stockés dans le code en phase 1 ; une table de gabarits modifiables n'a d'intérêt que si des non-développeurs doivent les éditer.

Expéditeur : l'adresse « De » vient toujours de `brand_email_settings.sender_email` , jamais d'une saisie utilisateur. Le nom affiché est celui de la marque, et `reply_to` renvoie vers l'adresse de la marque, pour que la réponse du client arrive à la bonne équipe. Chaque marque envoie depuis son adresse, sur son propre domaine : l'utilisateur ne choisit pas l'expéditeur, il découle de la marque du document. Recommandation : une boîte partagée Microsoft 365 par marque (par exemple facturation@…) plutôt que la boîte d'une personne, pour que l'envoi ne dépende d'aucun salarié ; l'éligibilité sans licence dédiée est à confirmer par votre administrateur.

Variables disponibles

Variable	Source
`{{brand_name}}`	`brand_email_settings.sender_name`
`{{client_contact}}`	contact saisi sur le document (`clientContact`) ; à défaut « Madame, Monsieur »
`{{client_company}}`	entreprise saisie sur le document (`clientCompany`)
`{{number}}`	`proformas.number` ou `invoices.number`
`{{title}}`	champ « Titre / objet » du document, s'il est renseigné
`{{amount}}`	`amount` , formaté `1 250 000 FCFA TTC` (séparateur d'espace)
`{{valid_until}}`	date d'émission plus la validité en jours
`{{paid_on}}`	`proformas.payment_received_at` (gabarit facture)
`{{seller}}`	nom du compte connecté (`user_metadata.name`)
`{{brand_phone}}`	téléphone de `profile_snapshot`
`{{signature}}`	`brand_email_settings.signature_text`

Gabarit proforma

```
Objet : {{brand_name}} — Proforma n° {{number}}

Bonjour {{client_contact}},

Veuillez trouver ci-joint la proforma n° {{number}} d'un montant de
{{amount}}, valable jusqu'au {{valid_until}}.

Pour la confirmer ou poser une question, répondez à ce message
ou appelez-nous au {{brand_phone}}.

Pour votre sécurité, nos coordonnées bancaires ne changent jamais
sans confirmation téléphonique de notre part.

Cordialement,
{{seller}}
{{signature}}
```

Gabarit facture : même structure, objet `{{brand_name}} — Facture n° {{number}}`, et la phrase centrale devient « ci-joint la facture n° {{number}} correspondant à votre commande, dont le règlement a été enregistré le {{paid_on}} ».

Gabarit relance : objet `Rappel — Proforma n° {{number}} en attente de règlement`, ton courtois, même mise en garde sur les coordonnées bancaires.

Règles de fabrication

- Deux versions envoyées ensemble, texte brut et HTML simple, sans image distante.
- Le message modifié par l'utilisateur est traité comme du texte : échappé, retours à la ligne conservés, aucun HTML accepté.
- Les retours à la ligne sont retirés de l'objet, pour éviter l'injection d'en-têtes.
- Pas de pixel de suivi d'ouverture : peu fiable, et mal vu côté vie privée. Le statut `delivered` suffit.
- La mise en garde sur les coordonnées bancaires répond à la fraude au RIB, qui consiste à faire payer un faux IBAN à un client.

9. Sécurité et confidentialité

Le risque principal est l'abus de l'envoi par un compte non autorisé ; il se traite par l'approbation des comptes, des quotas et une restriction stricte des boîtes utilisables.

Risque	Mesure
Un compte créé librement envoie des e-mails au nom de l'entreprise	`approved_at` exigé par la route. L'inscription reste ouverte mais inactive jusqu'à validation par un admin. Idéal : liste de matricules 3CX autorisés.
L'application peut envoyer au nom de n'importe quelle boîte	L'autorisation d'envoi par application couvre par défaut toutes les boîtes de l'organisation. Un administrateur Exchange Online la restreint aux boîtes de marque (contrôle d'accès par rôle pour les applications), puis teste un envoi depuis une boîte hors périmètre : il doit être refusé.
Usurpation de l'adresse « De », spam	Adresse « De » lue en base, jamais saisie. Seules les boîtes de marque sont autorisées côté Microsoft.
Envoi massif ou vers n'importe qui	5 destinataires au plus, quota par heure, journal de chaque envoi.

Risque	Mesure
Fraude au RIB	Envoi depuis les boîtes de marque, mise en garde dans chaque message, coordonnées bancaires uniquement dans le PDF figé.
PDF falsifié ou détourné	Signature `%PDF`, taille limitée à 3 Mo, chemin forcé dans le dossier de l'utilisateur, empreinte SHA-256 enregistrée, fichiers immuables dans Storage.
Injection dans le message ou l'objet	Texte échappé, aucun HTML libre, retours à la ligne retirés de l'objet.
Fuite de secrets	Variables Vercel côté serveur : `MS_TENANT_ID`, `MS_CLIENT_ID`, `MS_CLIENT_SECRET`, `SUPABASE_SERVICE_ROLE_KEY`. Date d'expiration du secret notée avec un rappel. Jamais dans `index.html` ni dans Git.
Lecture des envois d'un autre utilisateur	RLS `user_id = auth.uid()`, lecture seule.
Envoi SMTP avec mot de passe	Écarté : Microsoft prévoit de le désactiver par défaut fin décembre 2026. Graph utilise OAuth.

Clé de service : elle est déjà utilisée par `api/client-form.js`. Les deux nouvelles routes ne l'emploient que pour écrire dans `email_messages` et `activity_events`. Le badge sur les documents est mis à jour par un déclencheur, pas par la route.

Données personnelles : les e-mails de vos clients sont des données personnelles. Il faut fixer la durée de conservation du journal et des PDF, et informer les clients. La loi ivoirienne n° 2013-450 sur la protection des données et l'ARTCI sont à consulter ; je ne suis pas juriste, faites valider ce point par la personne compétente chez vous.

Cet audit rejoint deux constats déjà faits sur le projet : le répertoire `contacts` est lisible et supprimable par tout compte connecté, et d'après le README, un token VosFactures a déjà été transmis. L'approbation des comptes limite le premier aux comptes validés, sans remplacer des droits plus fins (suppression réservée aux admins, par exemple). Le second se règle par la révocation du token, si ce n'est pas déjà fait.

10. Interface

Cinq écrans ou fenêtres reçoivent des ajouts ; le plus important est la fenêtre « Envoyer par e-mail » ouverte depuis Archives.

Écran	Ajout
Archives	Bouton « Envoyer par e-mail » sur chaque proforma et facture. Badge d'état : « Envoyée le … », « En cours », « Rebond », « Échec ». Liste des envois du document (date, destinataires, statut) avec un bouton « Renvoyer ».
Fenêtre d'envoi	Champs À, Copie, Objet et Message préremplis par le gabarit. La copie interne de la marque est affichée, pas cachée. Aperçu du PDF qui sera joint. Bouton « Envoyer » inactif pendant l'envoi, message d'erreur lisible pour chaque code (403, 422, 429).
Éditeur	Après « Enregistrer la proforma », proposition « Envoyer maintenant ». Si les prix manquent (demande issue du formulaire client), l'envoi est refusé avec la raison.
Clients	Champs « Responsable » (nom, e-mail) sur la fiche et dans « Enregistrer dans le répertoire ».
Réglages d'envoi (admin)	Bloc séparé de l'onglet Identité, car il est enregistré en base et non dans le navigateur : expéditeur, adresse de réponse, copie interne, signature, par marque.

Après « Générer la facture », l'application propose d'envoyer la facture au même destinataire, avec le gabarit facture.

Approbation des comptes : en phase 0, un admin passe `approved_at` à la date du jour directement dans Supabase. Un écran « Comptes en attente » avec un bouton « Approuver » peut venir en phase 2.

Badges : ils se lisent depuis `last_emailed_at` et `email_send_count` pour la liste, et depuis `email_messages` pour le détail, ce qui évite une jointure à chaque affichage de la liste.

11. Suivi, historique et relances

Chaque envoi laisse deux traces : une ligne dans `email_messages` (le détail) et un événement dans `activity_events` (l'historique visible dans l'onglet Historique).

Événements d'historique proposés

`event_type`	Quand	`entity_type`
`document_email_sent`	Exchange Online a accepté l'envoi	`proforma` ou `invoice`
`document_email_failed`	L'envoi a échoué	`proforma` ou `invoice`
`document_email_bounced`	Rebond détecté dans la boîte de la marque	`proforma` ou `invoice`
`document_reminder_sent`	Une relance est partie	`proforma`

`entity_id` reçoit l'identifiant du document, `entity_number` son numéro, `client_label` le nom du client, et `source_event_id` l'identifiant de la ligne `email_messages`. Le champ `details` ne garde que des comptages et l'empreinte du PDF : les adresses restent dans `email_messages`, pour ne pas les copier dans un journal largement lisible.

Ce que « envoyé » veut dire : Exchange Online a accepté le message. Avec Microsoft Graph, on ne connaît la suite que si un rebond revient dans la boîte ; les statuts `delivered`, `delayed` et `complained` du schéma ne sont alimentés que si vous passez un jour à un fournisseur tiers. Cela ne prouve ni la lecture ni l'absence de classement en courrier indésirable.

Relances : elles visent les proformas, pas les factures. Une facture n'est émise qu'après paiement reçu (voir section 3). Les candidats à relance sont donc les proformas validées, non réglées et non converties :

```
create index if not exists proformas_reminder_idx
  on public.proformas (validated_at)
  where deleted_at is null
    and validated_at is not null
    and payment_received_at is null
    and invoice_id is null;
```

Déploiement en deux temps

1. **Relance manuelle** : un bouton « Relancer » dans Archives, qui préremplit le gabarit relance et passe par la même route et les mêmes contrôles.
2. **Relance automatique** : une tâche planifiée (Vercel Cron ou `pg_cron`) qui repère les candidats et envoie au nom de l'auteur de la proforma, après avoir vérifié que `brand_email_settings.is_active` est vrai et que le paiement n'est toujours pas enregistré.

Règle de relance à décider : proposition de départ, un premier rappel 3 jours après la validation, puis tous les 7 jours, 3 relances au maximum. Ces délais sont une suggestion, pas une donnée du projet. Le nombre de relances déjà faites se compte dans `email_messages` (`template = 'reminder'`), sans colonne supplémentaire.

La relance automatique est la dernière à activer : un e-mail parti sans relecture humaine, au nom de l'entreprise, mérite d'abord quelques semaines de relance manuelle.

12. Plan de déploiement et tests

Le MVP (envoi d'une proforma avec PDF, journalisé) tient en phase 0 et phase 1, soit 5 à 8 jours ; le total reste de 10 à 15 jours. Les durées sont des estimations en jours de développement, à confirmer.

Phase	Contenu	Durée estimée	Condition de sortie
0. Préparation	Décisions 1 à 5 (section 13), inscription d'application dans Microsoft Entra ID, restriction aux boîtes de marque dans Exchange Online, une boîte par marque, approbation des comptes existants	1 à 2 jours, selon la disponibilité de l'administrateur Microsoft 365	Un envoi de test part de la boîte d'une marque via Graph et apparaît dans ses éléments envoyés
1. MVP	`email-delivery.sql`, `api/send-document.js` (brouillon puis envoi Graph), PDF vers Storage, fenêtre d'envoi, journal, gabarits proforma et facture	4 à 6 jours	Une proforma réelle part vers une adresse de test avec un PDF conforme
2. Suivi	Détection des rebonds (lecture des e-mails d'erreur), badges, liste des envois, renvoi, réglages d'envoi par marque, écran d'approbation	2 à 3 jours	Un rebond de test s'affiche sur le document

Phase	Contenu	Durée estimée	Condition de sortie
3. Relances et extensions	Relance manuelle puis automatique, PDF côté serveur si la fidélité l'exige	3 à 4 jours	Une relance de test est reçue et journalisée

Tests avant mise en production

- [ ] Envoi avec un seul destinataire, puis avec copie client et copie interne
- [ ] Double clic sur « Envoyer » : un seul e-mail part
- [ ] Compte non approuvé : refus 403
- [ ] Proforma à `amount = 0` : refus 422
- [ ] Proforma supprimée : refus 404
- [ ] Document d'un autre utilisateur : refus 404 (RLS)
- [ ] Six destinataires : refus 422
- [ ] PDF de plus de 3 Mo, fichier non PDF, chemin d'un autre dossier : refus
- [ ] Adresse inexistante : rebond détecté dans la boîte de la marque, badge affiché
- [ ] Microsoft Graph indisponible : statut `failed`, bouton « Réessayer » disponible
- [ ] Envoi depuis une boîte hors périmètre de l'application : refusé par Microsoft
- [ ] Nouvel import VosFactures : `email_responsable` conservé
- [ ] PDF identique à l'aperçu sur Chrome, Edge et Safari mobile, sur un document de plusieurs pages
- [ ] Réception correcte sur Gmail, Outlook et la messagerie d'un client réel, hors courrier indésirable

Mise en production

- [ ] Export ou sauvegarde de la base avant le script
- [ ] Exécution de `email-delivery.sql` dans l'ordre des scripts, d'abord sur une copie de test
- [ ] Vérification que les comptes existants ont `approved_at` et qu'un compte admin existe
- [ ] Une ligne `brand_email_settings` par marque
- [ ] Variables d'environnement Vercel renseignées (identifiants de l'application Microsoft), puis redéploiement
- [ ] Essai sur une adresse interne, puis sur un client pilote
- [ ] Suivi des rebonds et des plaintes pendant la première semaine

13. Risques, décisions ouvertes et prochaines étapes

Six décisions sont à prendre avant de coder ; les trois premières bloquent la phase 0.

#	Décision	Proposition
1	Qui est le « responsable de la structure » : le responsable côté client, le responsable interne de la marque, ou les deux ?	Les deux, avec des champs distincts (`email_responsable` et `internal_cc`)
2	Voie d'envoi : Microsoft Graph depuis vos boîtes, ou fournisseur tiers ?	Microsoft Graph, si votre administrateur Microsoft 365 peut créer l'inscription d'application et la restreindre aux boîtes de marque
3	Quelles boîtes d'envoi : une boîte partagée par marque, ou la boîte d'une personne ?	Une boîte partagée par marque (par exemple facturation@…), éligibilité sans licence à confirmer ; l'utilisateur ne choisit pas l'expéditeur
4	Quelle méthode de PDF ?	Dans le navigateur d'abord, côté serveur seulement si la fidélité pose problème
5	Qui est admin de l'application et qui est administrateur Microsoft 365 ?	Un ou deux responsables pour chaque rôle (`role = 'admin'` côté application)
6	Quelles règles de relance et de conservation ?	Relance manuelle d'abord ; durées de conservation validées par votre juriste

Risques

Risque	Parade
Application autorisée à envoyer depuis toutes les boîtes de l'organisation	Restriction Exchange Online aux boîtes de marque, puis test d'un envoi depuis une boîte hors périmètre
Secret d'application expiré : les envois échouent d'un coup	Date d'expiration notée, rappel en agenda, alerte si Graph répond « non autorisé » ; un certificat plutôt qu'un secret si possible
Rebonds peu visibles faute de webhook	Phase 2 : lecture des e-mails d'erreur ; en attendant, statut « envoyé » seul et surveillance de la boîte

Risque	Parade
Limites d'envoi et de débit d'Exchange Online	Volume faible ici ; vérifier les limites de votre abonnement, gérer un refus par le statut `failed` et un renvoi manuel
PDF différent de l'aperçu A4	Tests multi-navigateurs ; bascule vers le rendu serveur en phase 3
Adresses de `contacts.emails` mal formatées	Audit avant la phase 1 (requête ci-dessous) ; analyse tolérante (virgule, point-virgule, espace)
Écart de numérotation si les documents sont un jour synchronisés avec VosFactures	Ne pas synchroniser sans règle de numérotation décidée
Dépendance à Microsoft Graph	Un seul fichier d'adaptation (`lib/email-provider.js`) : passer à un fournisseur tiers ne touche pas le reste
Clé de service utilisée dans de nouvelles routes	Routes minimales, écriture limitée à `email_messages` et `activity_events`
Limites d'exécution et de taille des fonctions Vercel	À vérifier selon votre plan ; l'envoi reste léger car le PDF est déjà produit côté navigateur
Brouillons et identités stockés dans le navigateur	L'envoi ne concerne que les documents enregistrés ; les réglages d'envoi vivent en base

Audit à lancer avant la phase 1 pour connaître l'état réel des adresses :

```
select count(*) as total,
       count(*) filter (where emails is null or btrim(emails) = '') as
sans_email,
       count(*) filter (where emails ~* '^[^@[:space:],;]+@[^@[:space:],;]+
[.][^@[:space:],;]+$') as une_adresse_valide,
       count(*) filter (where emails ~ '[,;]') as plusieurs_adresses
from public.contacts;
```

Prochaines étapes

1. Trancher les décisions 1 à 3.
2. Faire créer par l'administrateur Microsoft 365 l'inscription d'application, sa restriction aux boîtes de marque et les boîtes partagées.
3. Lancer l'audit des adresses et corriger les cas évidents.
4. Exécuter `email-delivery.sql` sur une copie de test de la base.

5. Démarrer la phase 1.

Je peux ensuite écrire le code de `api/send-document.js`, du suivi des rebonds et de la fenêtre d'envoi, adapté à votre `index.html`, dès que je vois le fichier.